🛡️ Weekly IT Security Brief (Official-source-first) | 2026-10-25 06:00

Formatted for readability · Auto-generated

📌 Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-114625(2026-10-26), CVE-2026-110447(2026-10-26), CVE-2026-106931(2026-10-23). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks. Microsoft Threat Intelligence analyzes the LiteLLM 1.107.0 compromise, including Python startup hooks, credential theft, remote code loading, d...
- Threat trend #2: AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise. Storm-0940 used ARTEX agentic AI to accelerate a ConnectWise supply chain compromise, enabling application credential abuse across Microsoft 365 environ...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

🔎 Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-114625

CVE Title	CVE-2026-114625 | arista/velocloud_orchestrator | Unknown Type
CVE Description	VeloCloud Orchestrator (VCO) on-prem has a security issue where this issue may allow a remote attacker to access privileged internal functionality and impact the VCO host. Successful exploitation may compromise the confidentiality, integrity, and availability of the orchestrator and data managed by the orchestrator.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	arista/velocloud_orchestrator
Risk Score	9.9 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-26
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-114625

CVE-2026-110447

CVE Title	CVE-2026-110447 | 待核實 | Remote Code Execution
CVE Description	Collabora Online Built-in CODE Server before 26.4.303 (richdocumentscode), a Nextcloud app, allows remote code execution, as exploited in the wild in September and October 2026, a different vulnerability than CVE-2025-66208. This is an OS command injection in proxy.php when the CODE server isn't running (e.g., the product was recently restarted). The vulnerability is not present in standalone Collabora Online s...
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	待核實
Risk Score	待核實 (待核實)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-26
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-110447

CVE-2026-106931

CVE Title	CVE-2026-106931 | e-guardian/siteguard | Unknown Type
CVE Description	SiteGuard Server Edition contains an OS command injection vulnerability, which may allow an attacker to execute arbitrary OS commands with root or SYSTEM privileges on the system running the affected product.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	e-guardian/siteguard, freebsd/freebsd
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-106931

CVE-2026-96656

CVE Title	CVE-2026-96656 | plex/media_server | Unknown Type
CVE Description	Plex Media Server before 1.43.3.10861 allows an admin user to write arbitrary files that may be executed on load. The preference TranscoderH264Options is appended verbatim to x264's option string on every transcode. At startup, all .so files are run without signature, execute bit, or symbol checks.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	plex/media_server
Risk Score	7.2 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-96656

CVE-2026-96655

CVE Title	CVE-2026-96655 | plex/media_server | Unknown Type
CVE Description	Plex Media Server before 1.43.3.10861 allows an authenticated user to request arbitrary internal or external addresses via the '/video/:/transcode/universal' path parameter.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	plex/media_server
Risk Score	4.3 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-11-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-96655

🧪 Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-105391

CVE Title	CVE-2026-105391	待核實	Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-105391

CVE-2026-107274

CVE Title	CVE-2026-107274	待核實	Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-107274

CVE-2026-107345

CVE Title	CVE-2026-107345	待核實	Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-107345

CVE-2026-107772

CVE Title	CVE-2026-107772 | 待核實 | Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-107772

Report B: Threat Intelligence News (last 7 days)

Headline: Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks

Source	Microsoft Security Blog
Published	Fri, 23 Oct 2026 18:12:19 +0000
Key Takeaway	Microsoft Threat Intelligence analyzes the LiteLLM 1.107.0 compromise, including Python startup hooks, credential theft, remote code loading, detections, and mitigations. The post Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks appeared first on Micr Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/23/inside-the-litellm-1-107-0-supply-chain-compromise-credential-theft-through-python-startup-hooks/

Headline: AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise

Source	Microsoft Security Blog
Published	Wed, 21 Oct 2026 18:23:55 +0000
Key Takeaway	Storm-0940 used ARTEX agentic AI to accelerate a ConnectWise supply chain compromise, enabling application credential abuse across Microsoft 365 environments. The post AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

Headline: CISA, FBI and Partners Warn Organizations of SafePay Ransomware Actors Targeting Multiple Critical Infrastructure Sectors

Source	CISA News
Published	Wed, 21 Oct 26 12:00:00 +0000
Key Takeaway	CISA, FBI and Partners Warn Organizations of SafePay Ransomware Actors Targeting Multiple Critical Infrastructure Sectors Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-fbi-and-partners-warn-organizations-safepay-ransomware-actors-targeting-multiple-critical

Headline: CISA, FBI, NSA and International Partners Warn of China-based Cybersecurity Company Enabling Threat Actors to Target Multiple Critical Infr...

Source	CISA News
Published	Thu, 08 Oct 26 12:00:00 +0000
Key Takeaway	CISA, FBI, NSA and International Partners Warn of China-based Cybersecurity Company Enabling Threat Actors to Target Multiple Critical Infrastructure Sectors Worldwide Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/worldwide
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-fbi-nsa-and-international-partners-warn-china-based-cybersecurity-company-enabling-threat

Headline: I had plans for that second

Source	Cisco Talos Blog
Published	Thu, 22 Oct 2026 18:04:32 GMT
Key Takeaway	I had plans for that second Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/i-had-plans-for-that-second/

Headline: Compromised eMudhra intermediate certificates

Source	Cisco Talos Blog
Published	Wed, 21 Oct 2026 20:43:29 GMT
Key Takeaway	Compromised eMudhra intermediate certificates Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/compromised-intermediate-certificates/

Headline: Brotli Decoder Flaw Behind Node.js RCE Also Affects Bun, Python and Other Widely Used Software

Source	The Hacker News
Published	Sat, 24 Oct 2026 16:39:29 +0530
Key Takeaway	Tracked as CVE-2026-111497, the flaw allows crafted compressed data to overwrite past the end of a buffer and corrupt a program's memory, potentially Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	CVE exploitation
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-111497
Link	https://thehackernews.com/2026/10/brotli-decoder-flaw-behind-nodejs-rce.html

Headline: Leaked LiteLLM Master Key Let Attackers Steal GitHub Tokens and Hijack Release Pipeline

Source	The Hacker News
Published	Sat, 24 Oct 2026 16:33:33 +0530
Key Takeaway	LiteLLM on Friday revealed that an Agent Platform master key accidentally published to a public GitHub repository in late May 2026 ultimately allowed the threat actor to push a malicious version of the popular Python package. "On May 27, 2026, a configuration file was committed to the public LiteLLM Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/latera...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/leaked-litellm-master-key-let-attackers.html

Headline: In Other News: Tor Exit Relays Hijacked, Banks Spot Rogue AI Agents, Self-Rebuilding macOS Ransomware

Source	SecurityWeek
Published	Fri, 23 Oct 2026 14:23:37 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: Russia’s APT28 hit NATO defense firms, PingCAP source code stolen, ShinyHunters negotiator probe. The post In Other News: Tor Exit Relays Hijacked, Banks Spot Rogue AI Agents, Self-Rebuilding macOS Ransomware appeared first on SecurityWeek Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral move...
Summary Engine	extractive-rules
Threat Actors	APT28
Target	defense/待核實
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-tor-exit-relays-hijacked-banks-spot-rogue-ai-agents-self-rebuilding-macos-ransomware/

Headline: Mirai Botnet Operators Join PHP2Shell Attacks as ASLR Bypass Exploits Emerge

Source	SecurityWeek
Published	Fri, 23 Oct 2026 12:45:52 +0000
Key Takeaway	The post Mirai Botnet Operators Join PHP2Shell Attacks as ASLR Bypass Exploits Emerge appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/mirai-botnet-operators-join-php2shell-attacks-as-aslr-bypass-exploits-emerge/

Headline: BlackX UEFI bootkit exploits Baton Drop flaw to bypass Secure Boot

Source	BleepingComputer
Published	Sat, 24 Oct 2026 10:17:32 -0400
Key Takeaway	A new UEFI bootkit named BlackX, deployed in an espionage campaign in early 2026, exploited the old Baton Drop vulnerability to bypass Secure Boot and load a malicious driver designed to interfere with security solutions from Kaspersky and Avast. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/blackx-uefi-bootkit-exploits-baton-drop-flaw-to-bypass-secure-boot/

Headline: Abandoned Popcorn Time app exposed millions of devices to RCE attacks

Source	BleepingComputer
Published	Fri, 23 Oct 2026 16:55:05 -0400
Key Takeaway	Researchers remotely disabled a vulnerable updater in the abandoned Time4Popcorn app, a fork of the Popcorn Time BitTorrent client, closing a security flaw that could have allowed attackers to execute malicious code with elevated privileges on millions of computers. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/abandoned-popcorn-time-app-exposed-millions-of-device-to-rce-attacks/

📚 Sources (official/authoritative first)

https://www.cisa.gov/known-exploited-vulnerabilities-catalog

https://nvd.nist.gov/

https://www.cve.org/

https://attack.mitre.org/

https://www.microsoft.com/en-us/security/blog/

https://www.cisa.gov/news-events/cybersecurity-advisories

https://www.mandiant.com/resources

https://blog.talosintelligence.com/